project-corebank 작업 정리

2026-11-05 · GitHub 연결·CI, 감사 로그, 원장 불변성, 횟수 제한, 로그인 잠금 해제 화면

백엔드 **github.com/Csj930205/project-corebank** 화면 **github.com/Csj930205/project-corebank-front**

250	80	161 / 357	V13
백엔드 테스트 +37	화면 테스트 +16	Postman 요청 / 검증 +18 / +37	DB 마이그레이션 +3 (V11~V13)

증가 폭은 어제 마감 기준(백엔드 213, 화면 64, Postman 143/320, V10). 모든 수치는 로컬과 GitHub Actions(Linux) 양쪽에서 통과.

1. 오늘 한 일

작업	내용	커밋
GitHub 연결	두 프로젝트를 git 저장소로 만들고 공개 저장소로 push. 비밀값(`.env`)은 제외됨을 확인. 커밋 작성자는 GitHub noreply 메일	`d45c44a, 0a04692`
CI	GitHub Actions. 백엔드는 Java 25 + Testcontainers(Oracle)로 전체 테스트, 화면은 lint·테스트·빌드. README 에 CI 배지	`837f569, 9b80968`
시각 정밀도 버그 수정	CI 첫 실행에서 발견. 아래 2절	`4a1d664`
감사 로그	API 요청마다 누가·언제·무엇을·어느 계좌에·결과. 조회 API 와 관리자 화면	`6763f15, 17c0e34`
원장 불변성	원장 거래·분개·이체 기록의 수정·삭제를 DB 트리거가 거부	`0b4dbfc`
횟수 제한	로그인 5번 연속 실패 시 15분 잠금, 수취인 조회 고객당 시간당 30번	`3495922, 06843e6`
로그인 잠금 해제 화면	잠긴 아이디 목록 API 와 관리자 "로그인 잠금" 탭. 아래 6절	`214d221, b2f09de`
Account 동등성	`equals` / `hashCode` 를 id 기준으로(지연 로딩 프록시 대응)	`dea8c60`

2. CI 가 찾아낸 버그: 시각 정밀도

증상

로컬(macOS)에서는 통과하던 `ClosureIntegrationTest.closeWithSameKeyReplaysFirstResult` 가 CI(Linux)에서만 실패. 같은 멱등성 키로 해지를 다시 보냈더니 해지 시각이 달랐다.

```
expected: 04:46:10.182550766   but was: 04:46:10.182551
```

원인

Linux 의 `LocalDateTime.now()` 는 나노초까지 주지만 컬럼은 `TIMESTAMP(6)` 이라 Oracle 이 마이크로초로 반올림해 저장한다. 처음 응답은 메모리 값(나노초), 재전송·재조회는 DB 값이라 1μs 어긋나 "같은 키면 처음과 같은 응답" 약속이 깨졌다. macOS 시계는 마이크로초 단위라 로컬에서는 드러나지 않았다.

수정

`common/DbTime.now()` (마이크로초에서 자름)를 만들고 시각을 직접 만드는 엔티티 6곳(계좌, 원장, 이체, 멱등성, 관리자, 고객)을 모두 바꿈. 테스트가 아니라 실제 코드를 고쳤다. 새 엔티티도 `DbTime.now()` 를 쓴다.

3. 감사 로그

"누가, 언제, 무엇을, 어느 계좌에 했고 결과는 어땠나" 를 요청마다 `audit_log` 에 한 줄씩 남긴다. 돈이 움직인 요청뿐 아니라 **조회**(잔액, 거래내역, 수취인 조회, 관리자 목록)와 **실패·거부된 시도**(로그인 실패, 401/403, 429, 잔액 부족)도 남긴다.

결정	이유
필터 하나가 기록	컨트롤러마다 로그 코드를 넣지 않는다. 무엇을 남길지는 `AuditAction` (메서드 + 경로 패턴) 목록이 정한다
토큰 확인 바로 앞에 위치	무효 토큰으로 401 을 받은 요청도 남고, 요청이 끝난 시점에도 누가 요청했는지 알 수 있다. 컨트롤러까지 가지 않은 요청도 남기려고 경로를 직접 맞춘다
업무 트랜잭션 밖에서 기록	잔액 부족으로 롤백된 출금도 에러 코드와 함께 남는다
본문은 남기지 않음	비밀번호가 기록될 일이 없다. 로그인 아이디·이체 계좌는 컨트롤러가 업무 처리 전에 `AuditContext` 에 적는다
`X-Request-Id` 응답 헤더	고객 문의를 받으면 그 번호로 기록 한 줄을 바로 찾는다
수정·삭제 거부 트리거(V11)	앱 계정이 탈취되어도 흔적을 지우지 못한다. 감사 기록을 조회한 것도 다시 기록된다

화면: 관리자 "감사 로그" 탭. 아이디·계좌·작업·결과·기간으로 검색하고, 조건은 주소에 담아 링크로 넘길 수 있다.

4. 원장 불변성: 막기와 찾기 두 겹

막기 (V12 트리거)

`ledger_transaction` , `ledger_entry` , `transfer` 에 UPDATE·DELETE 를 하면 ORA-20002 로 거부. 코드 버그나 SQL 직접 실행으로도 돈의 흔적이 바뀌지 않는다. 정정은 역분개(반대 거래 추가)로 한다.

찾기 (일 마감 대사)

트리거를 우회한 변경(소유자의 DDL 등)은 매일 대사가 찾는다. 대사 테스트는 `LedgerTampering` 으로 트리거를 잠시 끄고 원장을 틀어 놓은 뒤 찾아내는지 본다. 앱 코드에는 우회 경로가 없다.

계좌 잔액(`account.balance`)은 거래마다 바뀌는 값이라 막지 않고, 원장 합계와 같은지를 대사가 확인한다. 트리거가 켜져 있는지 확인하는 테스트도 있다.

5. 횟수 제한

	로그인 잠금	수취인 조회
규칙	아이디마다 5번 연속 실패 → 15분 잠금. 성공하면 처음부터	고객마다 1시간 구간(정시~정시)에 30번. 관리자는 제한 없음(감사 로그에 남음)
응답	429 `LOGIN_LOCKED` + `Retry-After`	429 `RATE_LIMITED` + `Retry-After`
저장	`login_attempt` (V13)	`rate_limit` (V13)
해제	시간이 지나거나 관리자 `POST /admin/login-locks/{username}/unlock`	다음 구간

핵심 설계

- **비밀번호 확인 전에 센다.** 확인 뒤에 세면 동시 요청 100개가 모두 "아직 0번" 을 보고 통과한다. 시도마다 행을 잠그고 (SELECT FOR UPDATE) 1을 더해 커밋한 뒤 확인한다. 동시에 10번을 보내는 테스트에서 비밀번호 확인은 정확히 한도만큼만 일어났다. 행 잠금은 BCrypt 확인 동안 잡지 않는다.
- **횟수는 롤백되지 않는다.** 로그인 실패는 예외로 롤백되므로 횟수는 `REQUIRES_NEW` 로 따로 커밋한다. 기존 `login` 이 `customerLogin` 을 내부 호출해 두 번 세어지는 문제도 함께 정리했다.
- **없는 아이디도 똑같이 잠근다.** 잠기는지로 계정 존재를 알아낼 수 없다.
- **DB 에 센다.** 서버가 여러 대여도 같은 기준. 막힌 요청은 감사 로그에 거부(DENIED). 하루 지난 기록은 매시간 정리.

6. 로그인 잠금 해제 화면

고객이 "로그인이 잠겼다" 고 하면 창구 직원이 본인 확인 뒤 15분을 기다리지 않고 바로 푼다. 해제 API 만 있고 잠긴 아이디를 볼 방법이 없어 목록 API 도 함께 만들었다.

구성	내용
목록 API	`GET /admin/login-locks` : 지금 잠긴 아이디(실패 수, 풀리는 시각), 곧 풀리는 순서, 최대 200개. 본 것도 감사 로그(`LOGIN_LOCK_LIST`)에 남는다
잠긴 아이디 목록	실패 수, 풀리는 시각, 남은 시간("12분 남음"). 잠금은 저절로 풀리므로 30초마다 다시 읽는다
두 번 눌러 해제	되돌릴 수 없는 동작이라 계좌 해지처럼 "해제" → "해제 확정". 취소하면 요청하지 않는다. 풀면 실패 횟수도 지워진다
로그인 기록 링크	줄마다 감사 로그(그 아이디의 로그인 시도)로 이어진다. 본인 실수인지 공격인지 보고 판단한다
아이디로 해제	목록에 아직 없는(방금 잠긴) 아이디는 직접 넣어 푼다
가입 안 한 아이디	목록에 함께 나온다. 계정 존재를 숨기려고 모든 아이디를 똑같이 잠그기 때문이고, 화면에도 안내한다. 모르는 아이디가 많으면 아이디를 바꿔 가며 시도하는 공격 신호일 수 있다

확인하며 고친 것과 찾은 것

- 화면의 공통 요청 함수가 본문 없는 성공 응답(204)에서 JSON 을 읽으려다 실패하던 문제를 고쳤다.
- 실제 서버에서 `/` 가 든 아이디는 풀 수 없었다(400). 서버가 보안상 경로 안의 인코딩된 `/` 를 거부한다. 실제 계정은 `/` 를 쓸 수 없어 누군가 아무렇게나 넣어 본 아이디만 해당되고 15분 뒤 저절로 풀리므로, API 는 그대로 두고 README 한계에 적었다. 테스트도 실제 서버 동작에 맞게 고쳤다.

7. 검증

항목	결과	새로 확인한 것
백엔드 테스트 (Testcontainers Oracle)	250 통과	감사 로그 17, 원장 불변성 4, 횟수 제한 11, 잠금 목록 2, Account 동등성 3
화면 테스트 (Vitest)	80 통과	감사 로그 화면·조건 6, 429 안내 3, 잠금 해제 화면·남은 시간 7
Postman 회귀 (실제 서버)	161 / 357 통과	11. 감사 로그(7 요청), 12. 횟수 제한(11 요청: 잠김 → 목록 → 해제 → 목록에서 빠짐)

GitHub Actions	모든 커밋 통과	백엔드·화면 각각, Linux 환경

8. 그 밖에

- **Account equals/hashCode:** IDE 가 만든 전 필드 비교(잔액 포함)는 입금 한 번에 같은 계좌가 다른 계좌가 되어 `Set` · `Map` 에서 찾지 못한다. id 기준으로 바꾸고, 해시는 클래스마다 고정(저장 전후로 불변), 지연 로딩 프록시를 위해 `instanceof` + `getId()`, `final` 아님.
- **README 정리:** 두 README 를 현재 상태로 맞춤(진행 상황, API·에러 표, 설계 섹션 순서, 테스트 수, 알려진 한계). 이미 끝난 "고객 화면 다음 작업" 같은 낡은 문장, 깨진 표 머리글 수정.
- **작업 방식:** 커밋은 이번 작업에서 바꾼 파일만 골라 올린다(`git add -A` 로 IDE 에서 고친 파일이 섞여 올라간 일이 있었다).

9. 남은 한계와 다음 후보

알려진 한계

- 불변성 트리거는 앱 계정이 테이블 소유자라 같은 계정의 DDL(ALTER TRIGGER, TRUNCATE)은 못 막는다 → 소유자·앱 계정 분리
- 감사 기록 쓰기가 실패해도 업무는 되돌리지 않음(ERROR 로그로 남김)
- password spraying(여러 아이디에 비밀번호 하나씩)은 아이디별 잠금으로 못 막음 → IP 단위 제한
- 남의 아이디로 일부러 틀려 15분 잠글 수 있음(잠금 방식의 공통 약점)
- 고정 구간이라 경계 앞뒤로 몰면 잠깐 2배까지
- `/` 가 든 아이디는 잠금 해제 불가(실제 계정에는 없고 15분 뒤 저절로 풀림)

다음 후보

- DB 계정 분리(소유자 / 앱: INSERT·SELECT 만)로 불변성 완성
- IP 단위 로그인 제한
- 정정(역분개) 거래와 승인 절차
- 일 마감 분산 잠금(ShedLock), 서버 여러 대 대비
- 리프레시 토큰, 토큰 강제 무효화
- 잠금 해제를 본문 방식(`{username}`)으로 바꿔 어떤 아이디든 풀 수 있게